Windows Threat Detection 3

Learn how threat actors manage to maintain access to the breached Windows hosts.

Task 1 – Introduction

What if attackers aren't satisfied with just breaching the host but aim to stay, establish control, and use the system as a starting point for future operations? This room completes your Windows threat detection journey and explores how a compromised host can become part of a larger attack, focusing on three tactics: Command and Control, Persistence, and Impact.

Learning Objectives

- Remind the concept of Command and Control (C2)
- Learn why and how threat actors maintain control of their victims
- Use Windows event logs to uncover various persistence methods
- See how the learned techniques work in a hands-on environment

Prerequisites

- Recall the basics of MITRE tactics and Windows logs
- Complete Windows Threat Detection 1 and 2 rooms
- Be ready to dive deeper into the last stages of Windows attacks

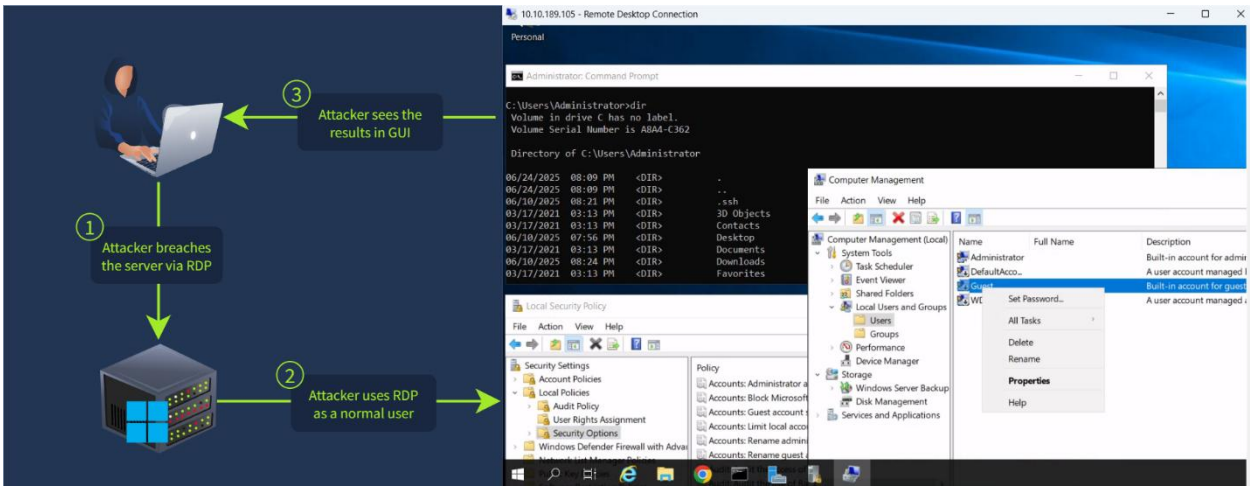
Task 2 – Command and Control

Command and Control

You already learned that USB worms and phishing attachments can "infect" the machine. But how do they do it exactly? How do threat actors send the commands and keep control of the victim's host? This task will shed light on this topic and explore the Command and Control (C2) MITRE tactic.

Attacks Without C2

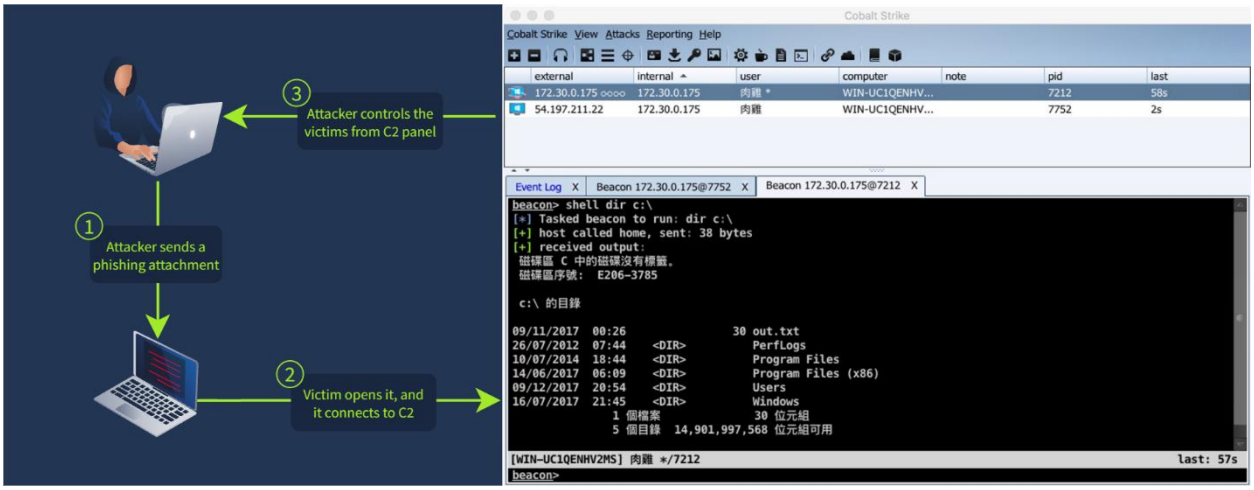
In some cases, C2 is not needed at all. For example, threat actors can type their commands directly in RDP the session after an RDP breach. Since this method becomes unavailable as soon as RDP is closed or secured, most threat actors choose to still set up a C2 immediately after the breach.



Simplest C2

For other Initial Access methods, threat actors can't simply use RDP every time they need to run a command, so they need some process that connects back to the attackers and waits for their commands 24/7. In the simplest case, the phishing attachment will be that process and establish the **Command and Control channel**, like on the CobaltStrike C2 screenshot below.

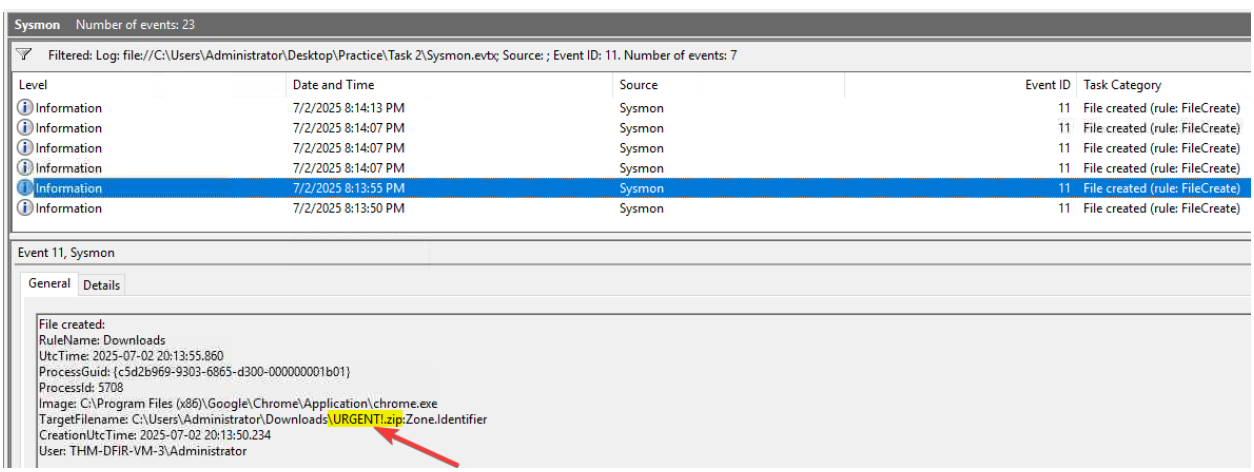
In more advanced cases, the attachment won't immediately connect back, but rather download an additional C2 malware, hide it in a folder like C:\Temp, and run it as a new stealthy process. This method is beneficial to keep the attack going if the victim decides to delete the original attachment. See how it worked in the recent ransomware cases and during the APT29 phishing campaign.



For this task, access the attached VM and detect the setup C2 using logs: **C:\Users\Administrator\Desktop\Practice\Task 2\.Sysmon.evtx**

Answer the questions below

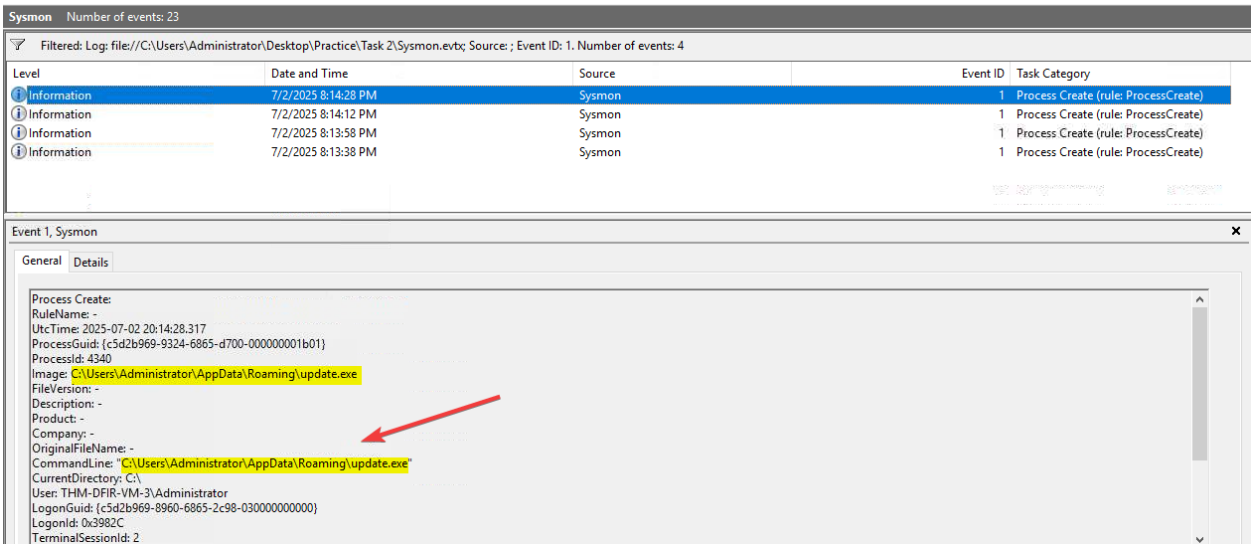
Which suspicious archive did the user download?



Sysmon Event ID 11 (FileCreate) showed the creation of the suspicious archive URGENT!.zip in the user's Downloads folder.

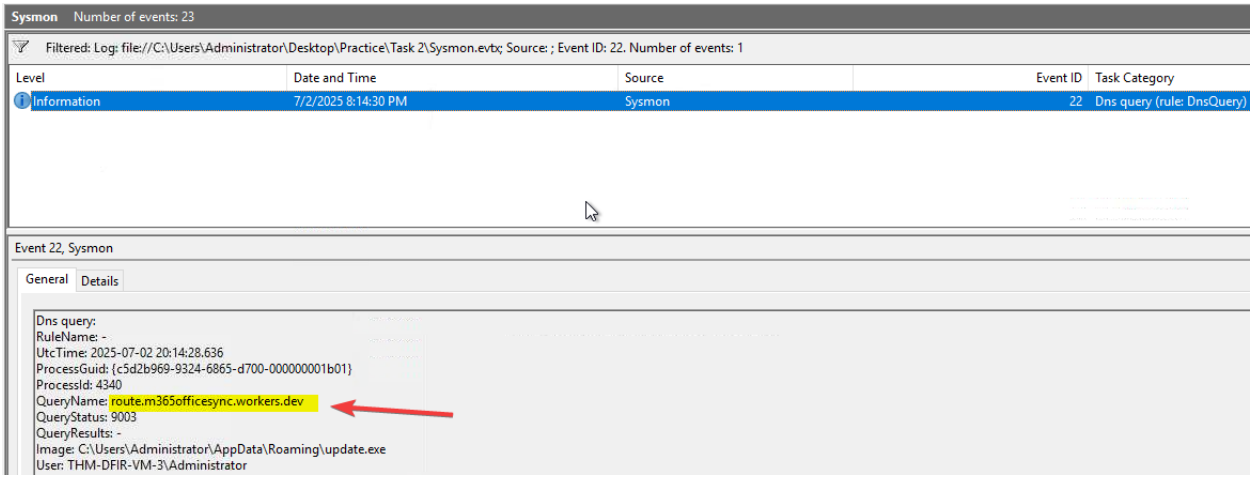
Answer: URGENT!.zip

Where did the attackers hide the C2 malware file?



The evidence was supported by multiple Sysmon events: Event ID 1 showed PowerShell downloading the malware and saving it to %APPDATA%\update.exe, while a later process creation event confirmed execution of C:\Users\Administrator\AppData\Roaming\update.exe.Answer: C:\Users\Administrator\AppData\Roaming\update.exe

What is the domain of the Command and Control server?



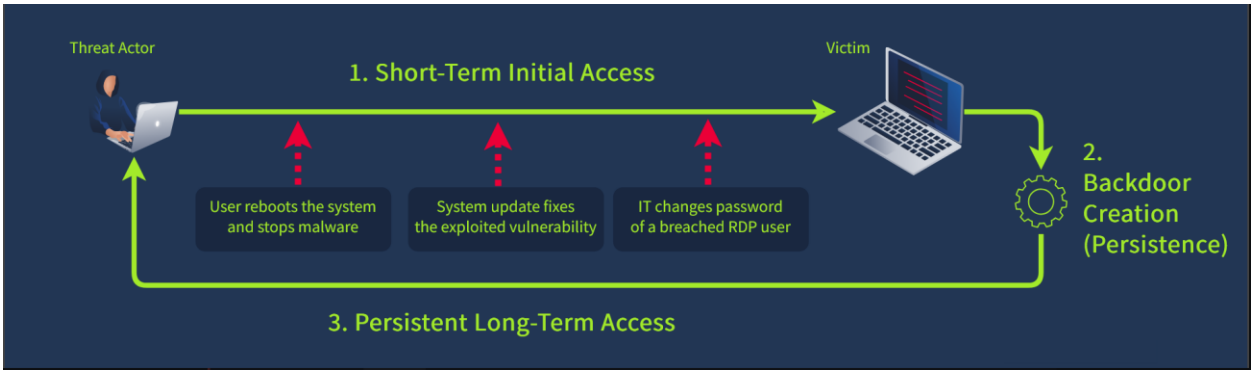
Sysmon Event ID 22 showed a DNS query from update.exe to route.m365officesync.workers.dev, identifying the Command and Control domain.

Answer: route.m365officesync.workers.dev

Task 3 – Persistence Overview

Persistence Overview

Data stealer infections usually have a very short lifespan: they breach the victim, collect the data, exfiltrate it, and exit - all within minutes. However, for most other attacks, maintaining access to the victim for days or even months after the Initial Access is vital. The tactic of maintaining reliable, long-term access to the target that can survive reboots and password changes is called Persistence - a big and interesting topic that you will discover soon.



Persisting via RDP

Many Windows breaches happen because of the exposed service: RDP with a weak password, a vulnerable mail server, or a misconfigured web app. For such scenarios, the threat actors can access the machine via the same exposed service over and over again until the vulnerability is fixed. Still, threat actors often deploy an additional Persistence method, for example:

- Create an additional hidden vulnerability in the breached service (e.g. a backdoor or a web shell)
- Create a new user (T1136), make it an administrator (T1098), and use it for further RDP logins

Let's focus on the second method now and see how you or threat actors can manage users on Windows. The first option is to use the graphical utility by searching for "Computer Management" or by launching lusrmgr.msc. The second option is to use a command line, like in the example below:

```
CMD and PowerShell Commands to Manage Users

# 1. Two methods to create the "mr.backd00r" user
CMD C:\> net user "mr.backd00r" "p@ssw0rd!" /add
PS  C:\> New-LocalUser "mr.backd00r" -Password [...]

# 2. Two methods to add the user to Administrators
CMD C:\> net localgroup Administrators "mr.backd00r" /add
PS  C:\> Add-LocalGroupMember "Administrators" -Member "mr.backd00r"
```

Detecting Backdoored Users

It's time to go back to the Security event logs! Every user creation event is logged as Security event ID **4720,** which you explored in the Windows Logging for room. Since threat actors can be very creative with naming the backdoored accounts, you should not rely just on detecting suspicious names like "hacker" but rather investigate:

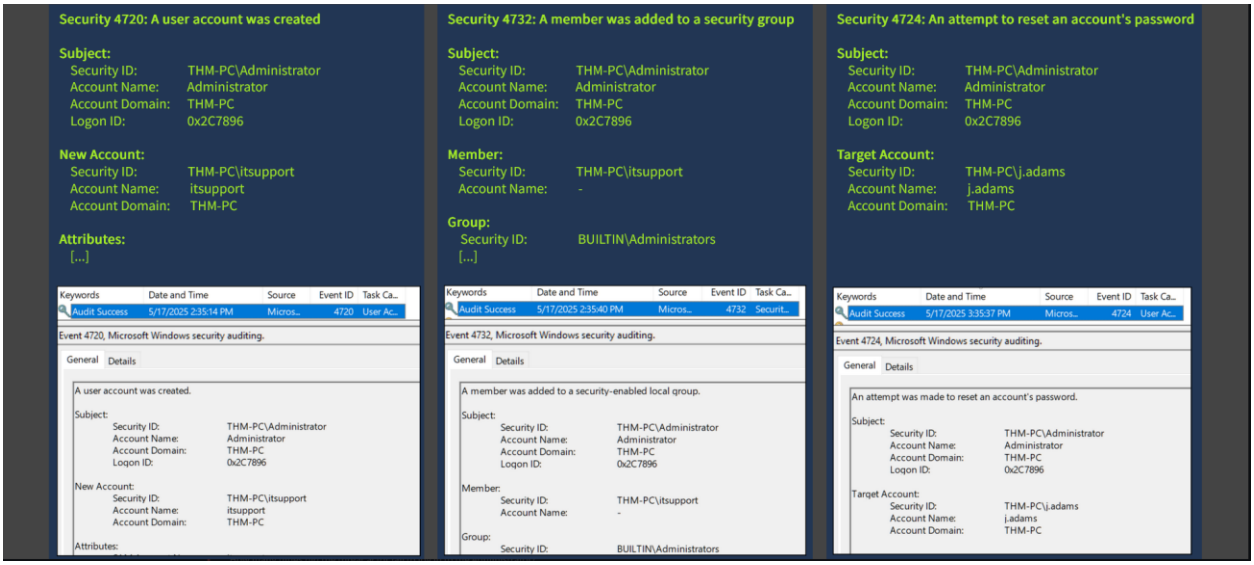
1. **Who** created the account? Can the person confirm the account creation?
2. **What** is the source IP and time of the creator's login? Is it expected?
3. **Which** other suspicious events can you see in the creator's session?

Making Users Privileged

Next, a new user by itself won't give the attacker much, as the default user permissions do not allow remote (RDP) logins or grant administrative privileges on the machine. To overcome this, threat actors will add their backdoored account to one of the privileged groups, which is tracked by Security event ID **4732**. The most commonly exploited groups are **Administrators** and **Remote Desktop Users**.

Resetting Passwords

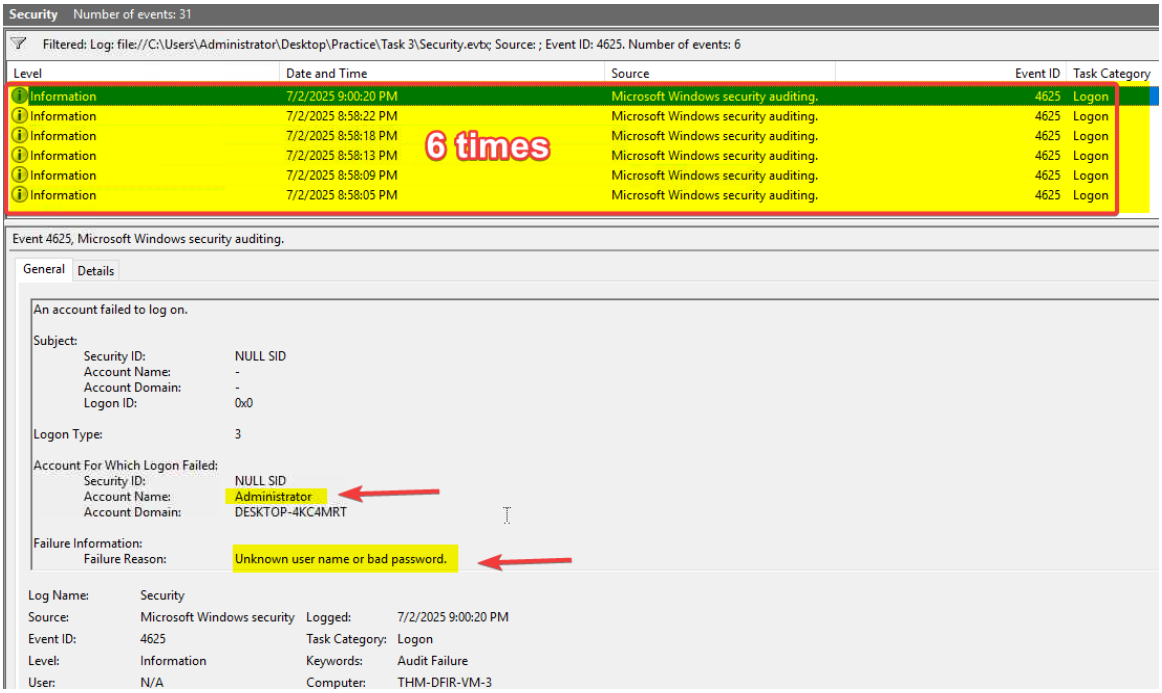
Lastly, in more advanced cases, threat actors may simply reset the password of some old or unused account and use it instead of creating a new one. You can detect it with Security event ID **4724**. In summary, below you can see how the described event IDs look like:



For this task, try to detect a persistence via the backdoored user account:
C:\Users\Administrator\Desktop\Practice\Task 3\Security.evtx

Answer the questions below

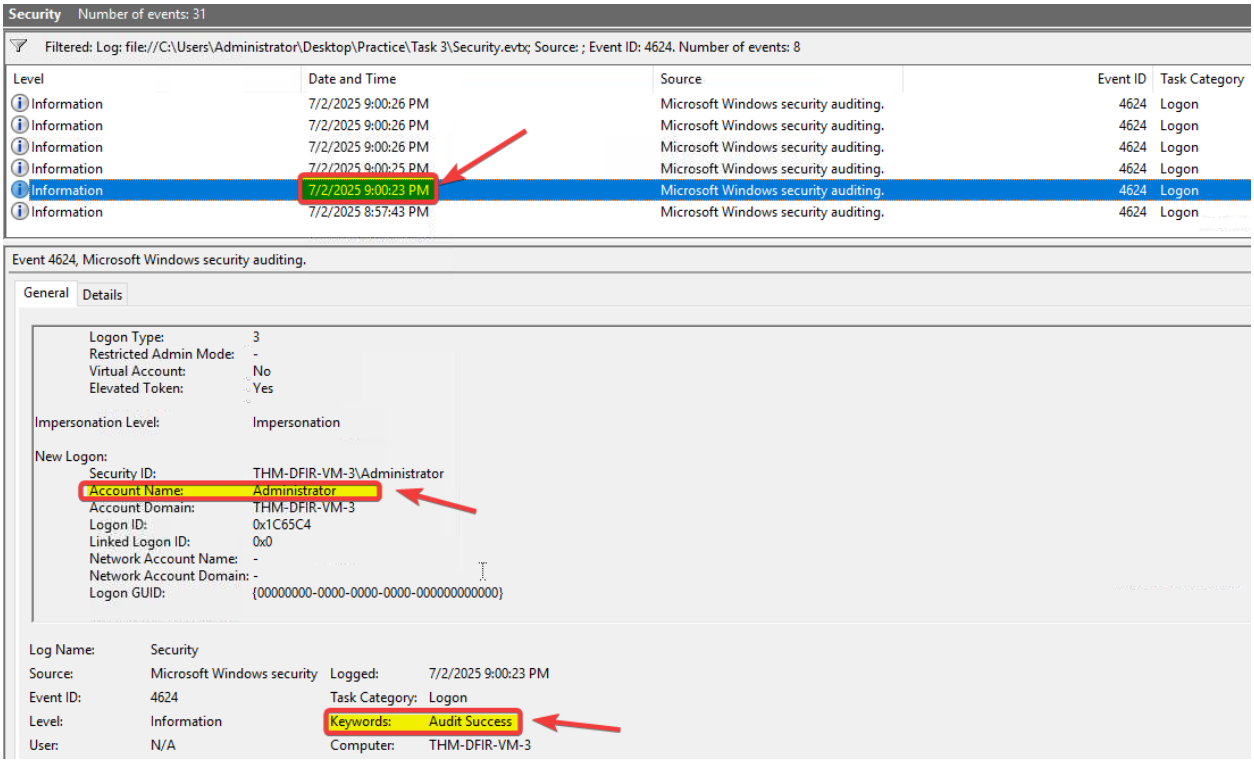
How many times did the threat actor fail to log in to the Administrator?



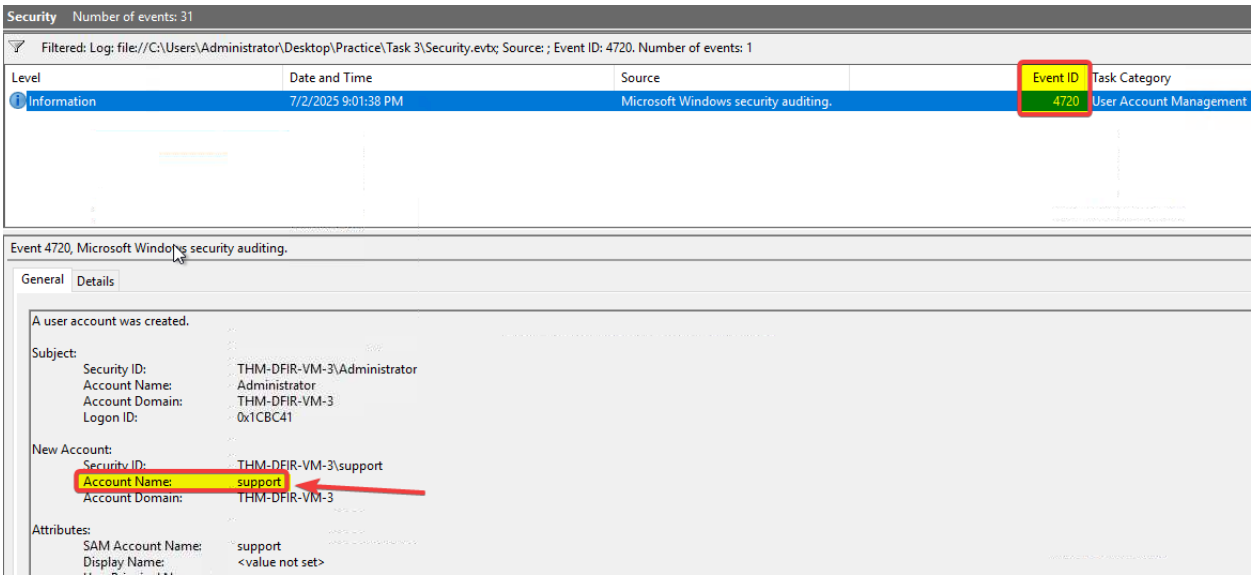
Security Event ID 4625 showed six failed logon attempts against the Administrator account.

Answer: 6

After the successful login, which backdoor user did the attacker create?



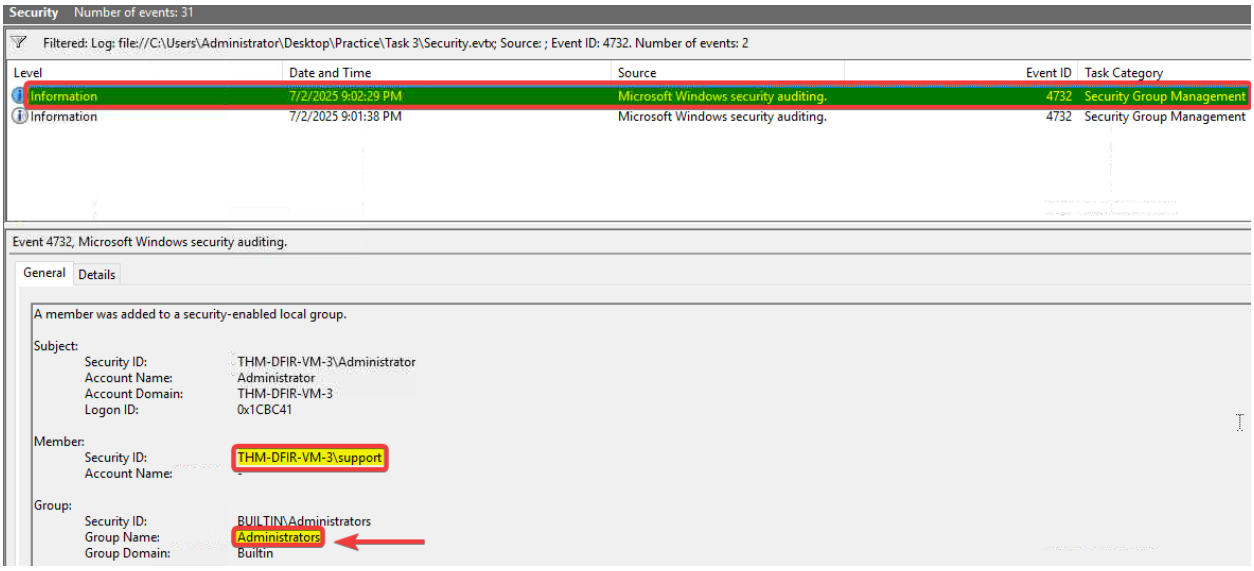
Security Event ID 4624 showed that the attacker successfully logged in to the Administrator account at 9:00:23 PM. Moments later, Event ID 4720 showed the creation of the backdoor account support.



Security Event ID 4720 showed that, after gaining access, the attacker created a new backdoor account named support.

Answer: support

Which privileged group was the backdoor user added to?



Security Event ID 4732 showed that the backdoor account support was added to the local Administrators group, giving it elevated privileges.

Answer: Administrators

Task 4 – Persistence: Tasks and Services

Malware Persistence

Persistence via a backdoored user works well if you can remotely log in to it via RDP, but if the attack started through a phishing attack or USB infection, that's not an option. For these scenarios, threat actors need an actively running malware that maintains a

connection with their C2 server even after a system reboot. How could they achieve malware persistence?

Services and Tasks

Unfortunately for defenders, there are literally a hundred or more methods to persist on a Windows machine. As a SOC L1 or L2 analyst, you don't need to know all of them, but let's start with the two common ones:

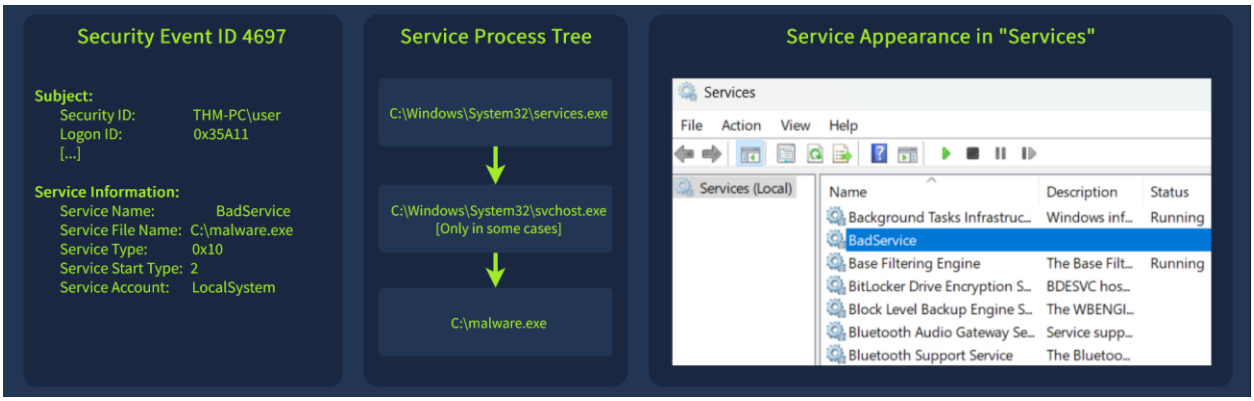
Persistence Method	**Attack Example**	**Event ID Logging**
Create a Windows Service (Runs after OS startup)	sc create "BadService" binpath= "C:\malware.exe" start= auto	**Launch of sc.exe:** Sysmon / **1** **Service creation:** Security / **4697**
Create a Scheduled Task (Run after OS startup)	schtasks /create /tn "BadTask" /tr "C:\malware.exe" /sc onstart /ru System	**Launch of schtasks.exe:** Sysmon/ **1** **Scheduled task creation:** Security / **4698**

Detecting Services

Many critical Windows components like DNS client or Security Center are services. You can view services by launching **services.msc** or searching for "Services", but you need administrative privileges and the **sc.exe** command to create or modify one.

Threat actors can create their own malicious services that will run the specified program on startup, and they do it very often, as you can read in the MITRE examples. In logs, you can detect malicious services in three ways:

1. Detect the launch of the sc.exe create command via Sysmon event ID **1**
2. Detect service creation via Security event ID **4697** or System event ID 7045
3. Detect suspicious processes with a services.exe parent process

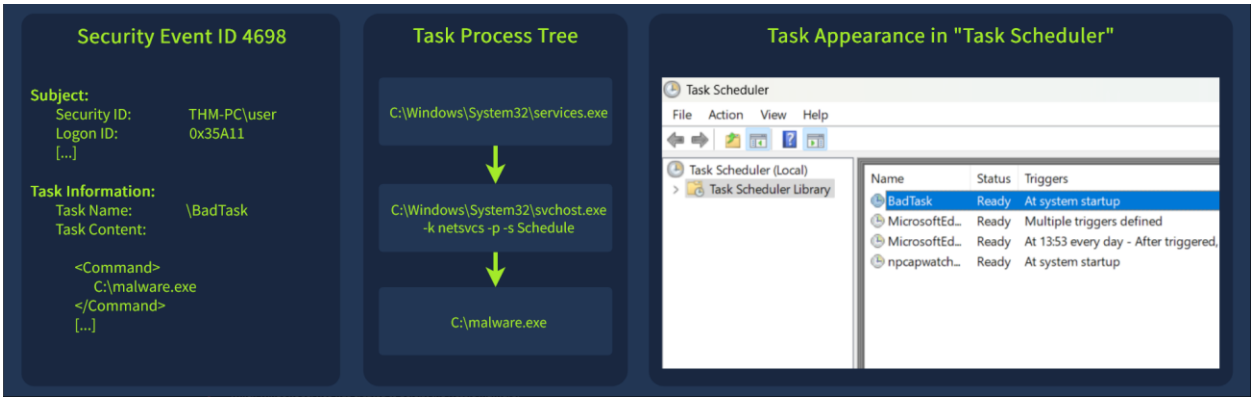


Detecting Tasks

Scheduled tasks are another Windows feature heavily used by both the OS and external apps (e.g. to check for updates or make a backup every hour). From GUI, you can manage tasks by launching **taskschd.msc** or searching for "Task Scheduler". From the command line, you can use the **schtasks.exe** command.

Unlike services, scheduled tasks are very easy to configure and hide, which is why they are the most common persistence method by threat actors, like in these APT28 and APT41 attacks. Similar to services, you can detect scheduled tasks in three ways:

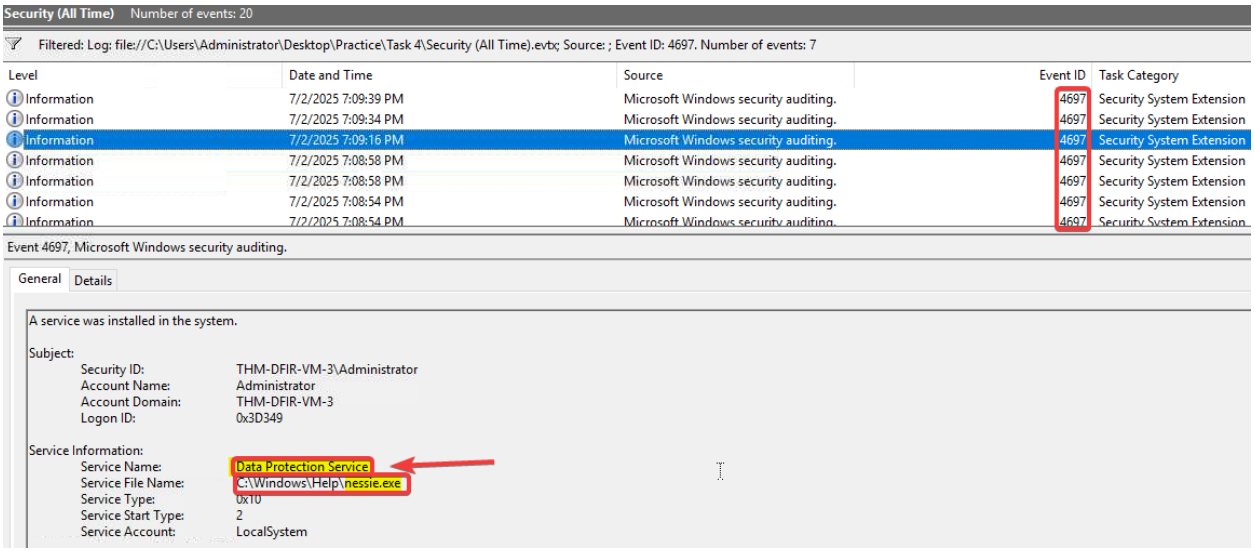
1. Detect the launch of the schtasks.exe /create command via Sysmon event ID **1**
2. Detect and analyze scheduled task creation events via Security event ID **4698**
3. Detect suspicious processes with a svchost.exe [...] -s Schedule parent



The attackers left two backdoors and restarted the system.
Can you uncover them all using Security and Sysmon logs?
C:\Users\Administrator\Desktop\Practice\Task 4

Answer the questions below

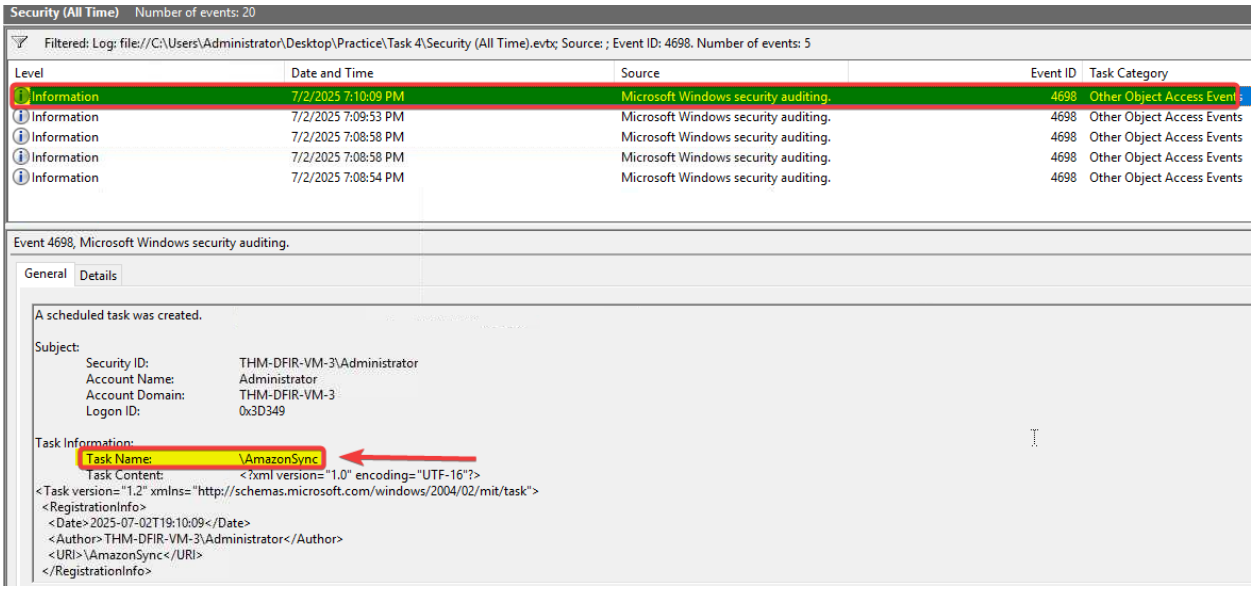
Which Windows service was created to persist the Nessie malware?

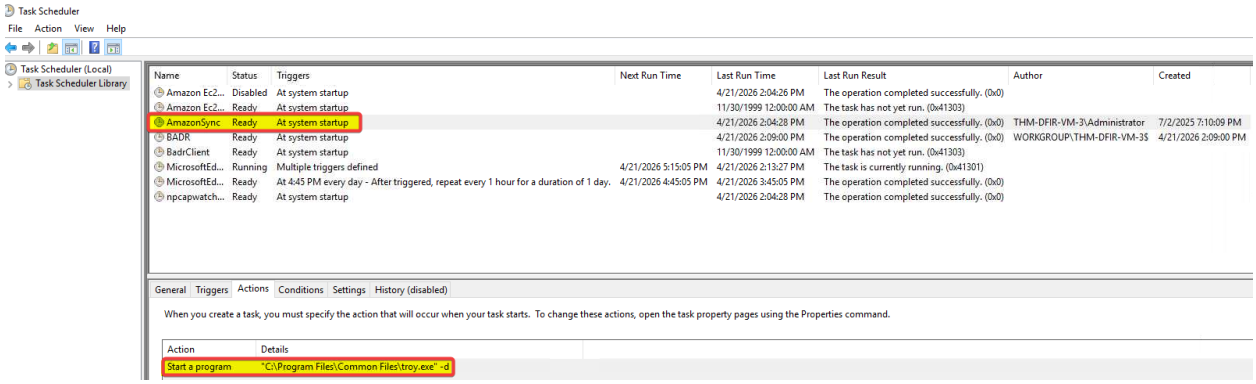


Security Event ID 4697 showed that the attacker installed a malicious service named Data Protection Service to persist the Nessie malware.

Answer:

Which scheduled task was created to persist the Troy malware?

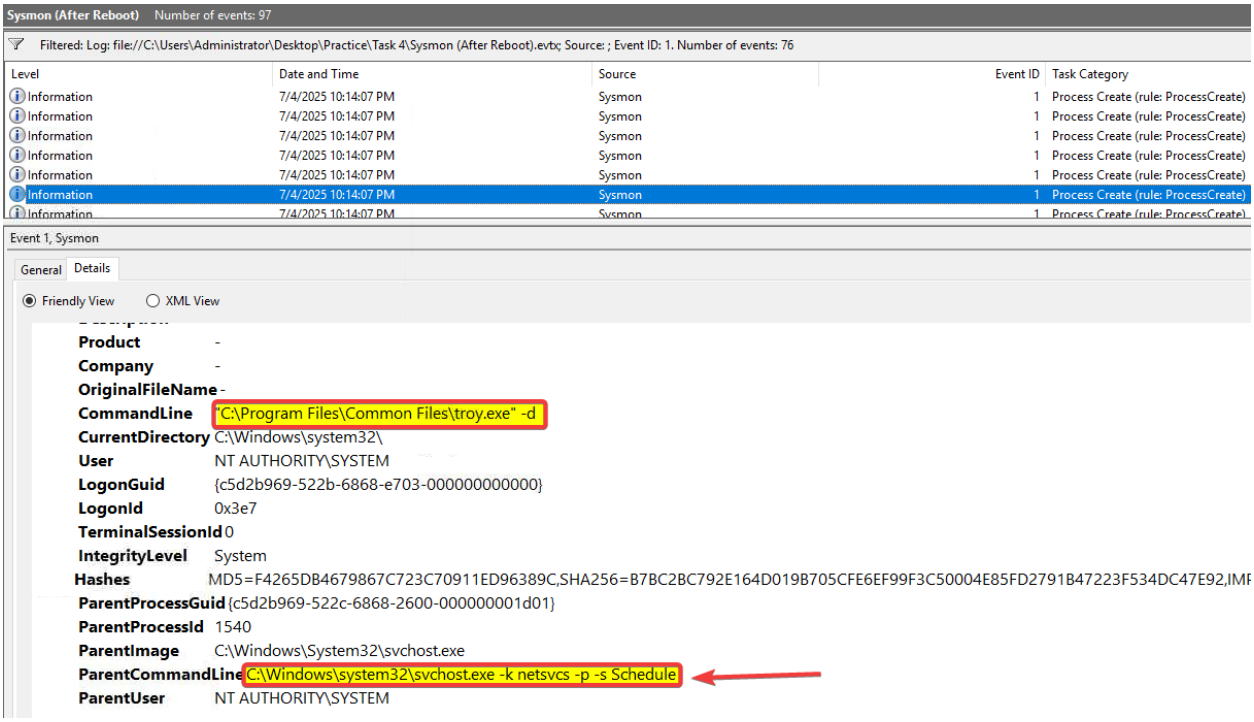


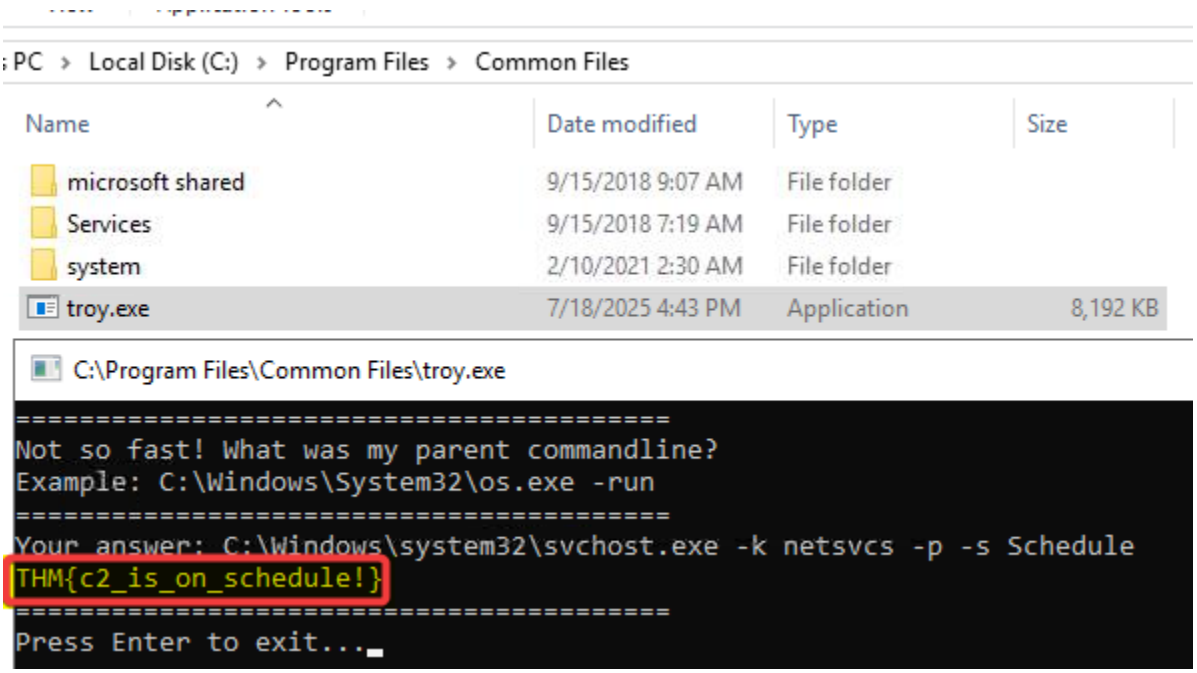


Event ID 4698 recorded the creation of the scheduled task \AmazonSync. Although scheduled tasks can be legitimate, this one was identified as malicious because it appeared during the attacker activity timeline and was configured to run troy.exe at startup. Reviewing the task action in Task Scheduler directly linked it to the Troy malware and confirmed it as a persistence mechanism.

Answer: AmazonSync

What flag do you get after finding and running the Troy malware?





After reboot, Sysmon Event ID 1 showed that troy.exe was launched by svchost.exe under the Schedule service. Running the malware and supplying the correct parent command line revealed the flag THM{c2_is_on_schedule}.

Answer: THM{c2_is_on_schedule!}

Task 5 – Persistence: Run Keys and Startup

Run Keys and Startup

Services and scheduled tasks are typically run on system boot and require administrative privileges to configure. However, what if a program has to run only when a specific user logs in? For such cases, Windows provides a few per-user persistence methods that are actively used by both legitimate tools and malware:

Persistence Method	Attack Example	Event ID Logging
Add malware to Startup Folder (Runs upon user login)	copy C:\malware.exe "%AppData%\Microsoft\Windows\Start Menu\Programs\Startup\malware.exe"	**New startup item:** Sysmon Event ID **11**
Add malware to "Run" keys (Runs upon user login)	reg add "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v BadKey /t REG_SZ /d "C:\malware.exe"	**New registry value:** Sysmon Event ID **13**

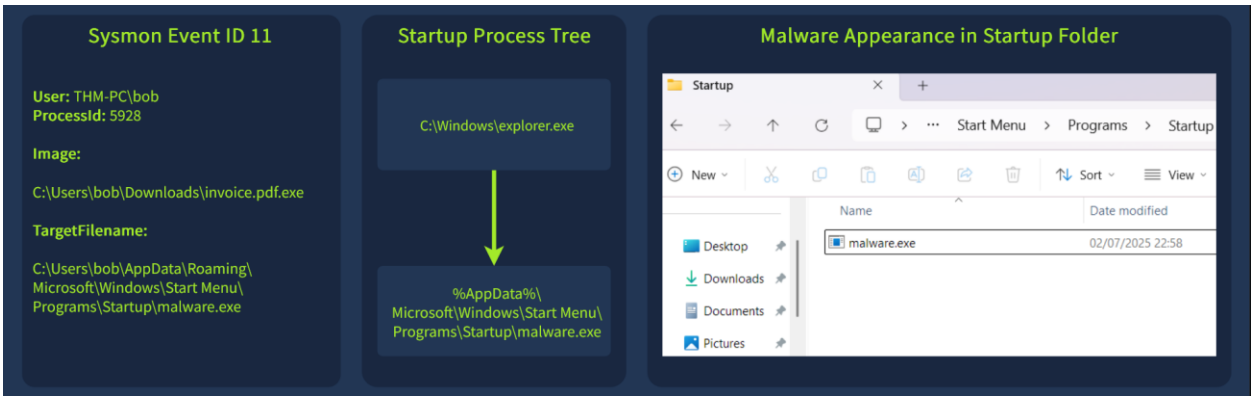
Detecting Startup

The startup folder was meant to be an easy way for inexperienced users to configure programs to run on login. You simply open the startup folder, move your program or program shortcut there, and see how it automatically starts upon your future logins. You can access your startup folder via the path below:

C:\Users\<USER>\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\

Or for all users: C:\ProgramData\Microsoft\Windows\Start Menu\Programs\StartUp

The startup folder is not a common choice for legitimate programs, so usually, the folder is empty. Still, threat actors often put their malware there (Lumma Stealer example), and you can detect it by monitoring file creation events (Sysmon Event ID **11**) inside the Startup Folder. Also, note that the programs launched via startup will have an explorer.exe parent, so it may be hard to differentiate them from legitimate user activity or attacks you learned in Windows Threat Detection 1:

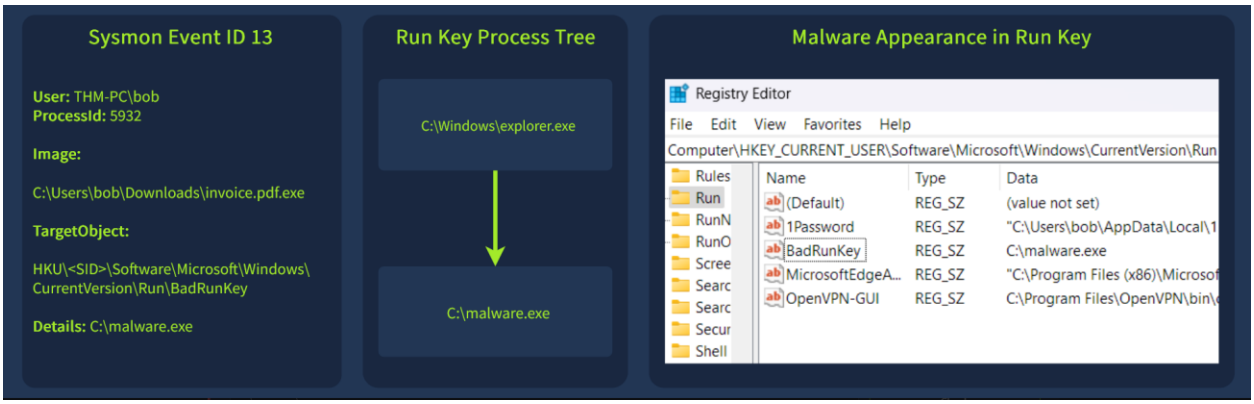


Detecting Run Keys

Run key persistence is very similar to the startup folder; they even share a single MITRE technique (opens in new tab)! The only major difference is how the entries are added there. Instead of just copying the program to the startup folder, you need to create a new value in the "Run" Windows registry and put the path to your program there:

HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run
Or for all users:
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run

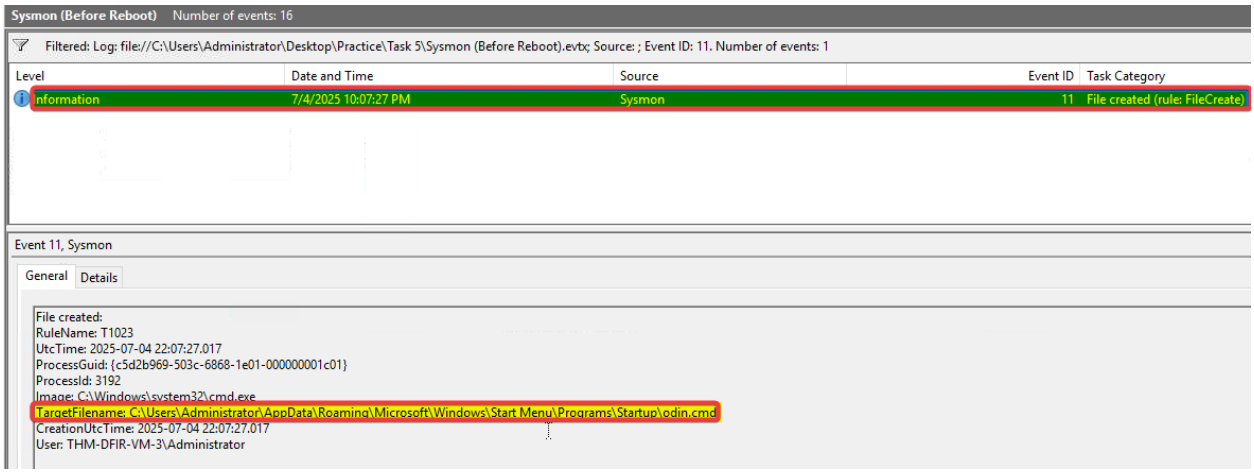
To view the "Run" entries, you can launch the regedit.exe or search for "Registry Editor" and go to the path shown above. To detect the malicious entry from logs, you can monitor registry change events (Sysmon Event ID **13**) affecting the Run keys:

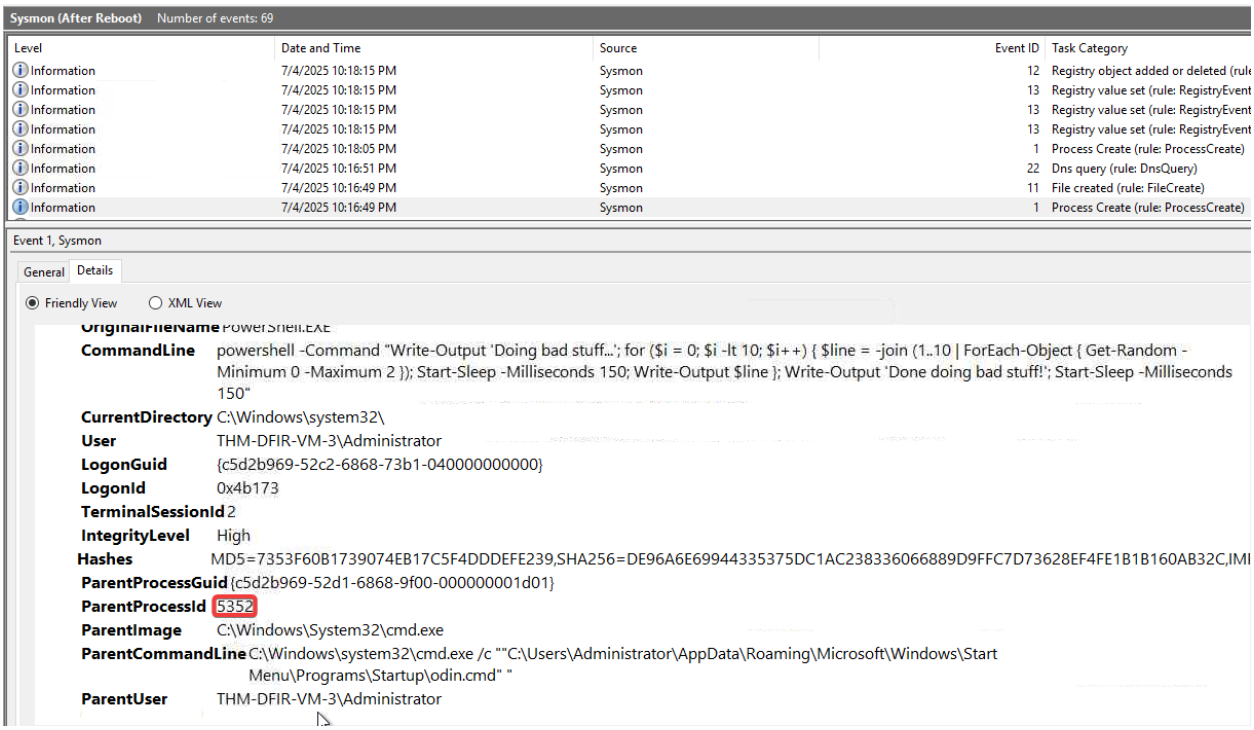


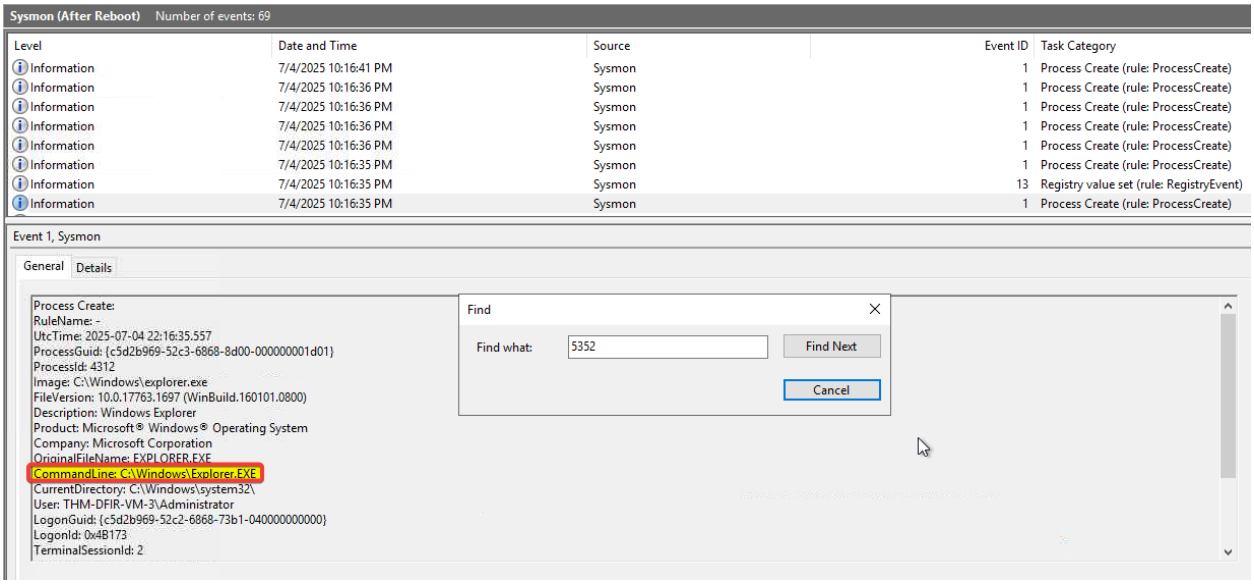
Use all the tools you know to uncover the newly learned backdoors!
C:\Users\Administrator\Desktop\Practice\Task 5

Answer the questions below

What is the parent process image of the "Odin" malware?



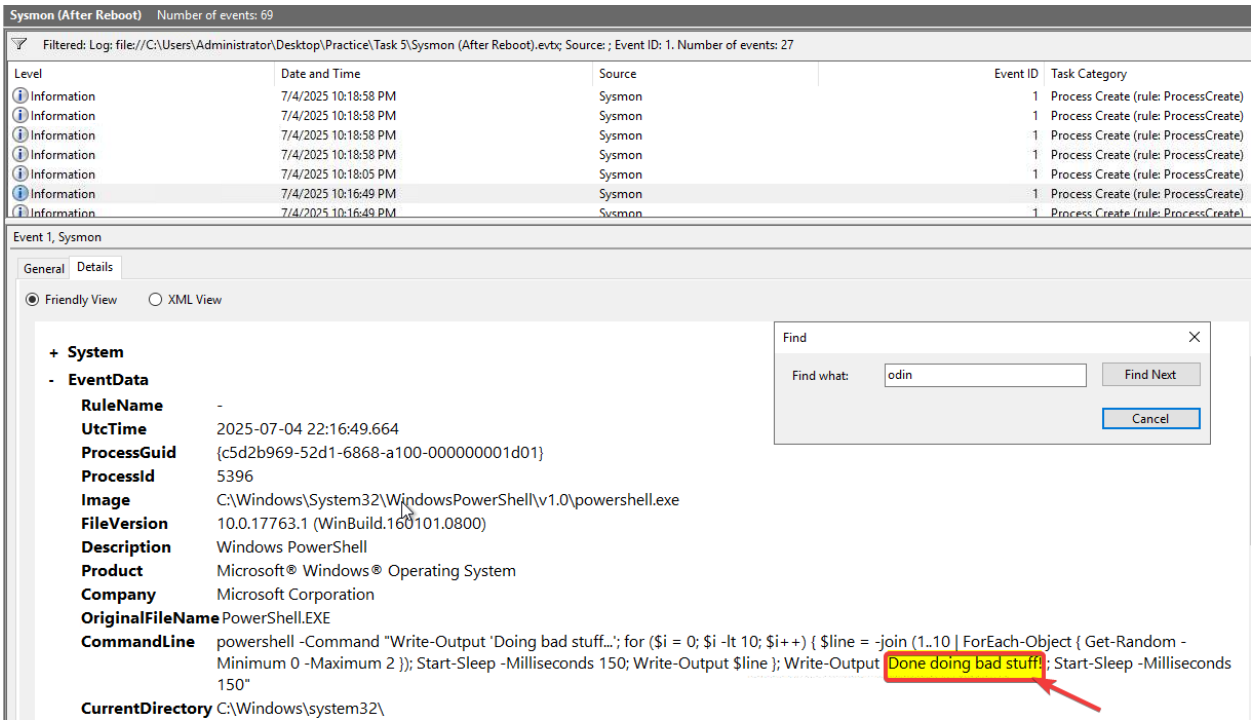




Sysmon correlation showed that cmd.exe created the startup script odin.cmd, which later launched PowerShell after reboot. Tracing the parent process chain back through Process ID 5352 showed that the parent process image was C:\Windows\explorer.exe.

Answer: C:\Windows\explorer.exe

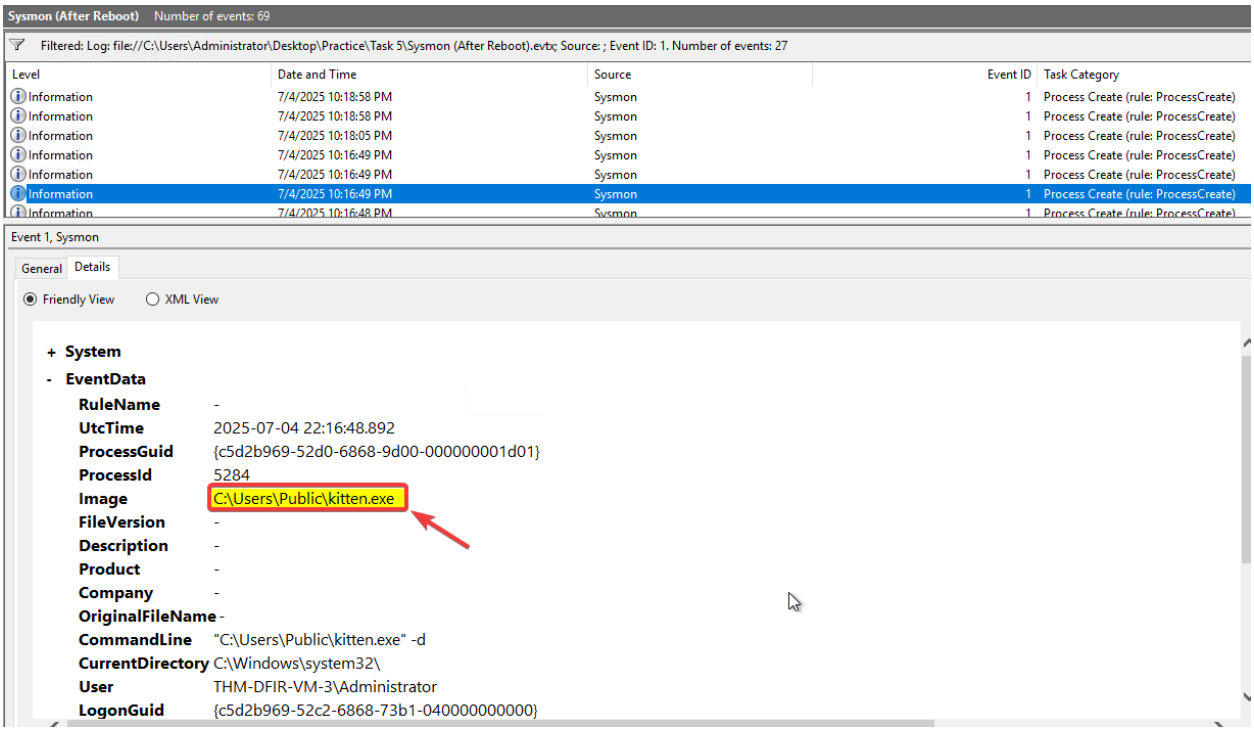
What is the last line that the "Odin" malware outputs?

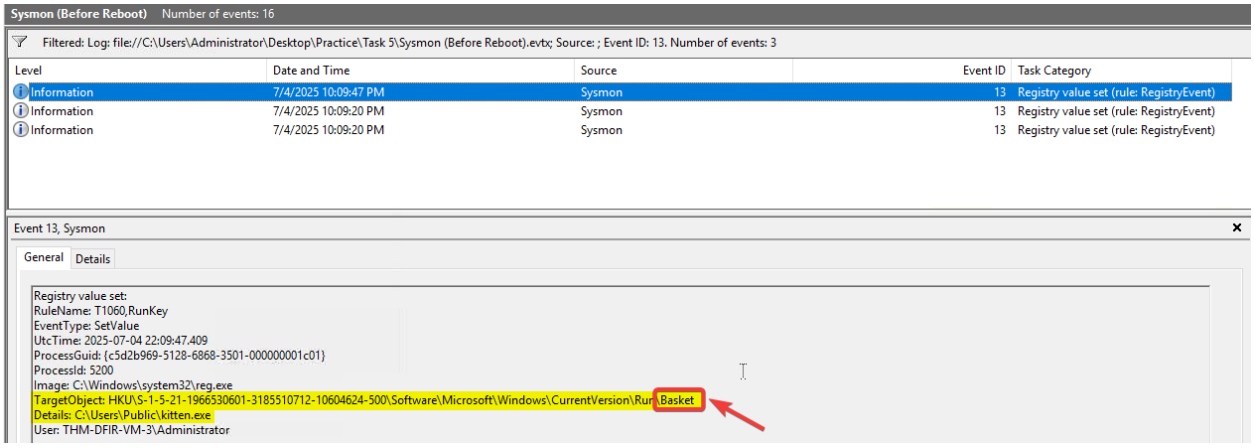


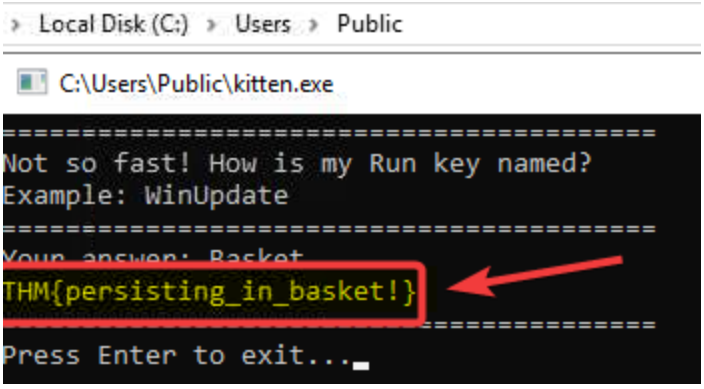
Using Find with odin in Sysmon Event ID 1 led to the PowerShell execution tied to the Odin malware, where the command line revealed the final output string: Done doing bad stuff!.

Answer: Done doing bad stuff!

What flag do you get after finding and running the "Kitten" malware?







First, Sysmon Event ID 1 was used to identify the Kitten malware process at C:\Users\Public\kitten.exe. Next, Event ID 13 was reviewed to find the Run key persistence entry, which showed the value name Basket under …\CurrentVersion\Run. Finally, running the malware and providing the correct Run key name revealed the flag THM{persisting_in_basket!}.

Answer: THM{persisting_in_basket!}

Task 6 – Impact and Threat Detection Recap

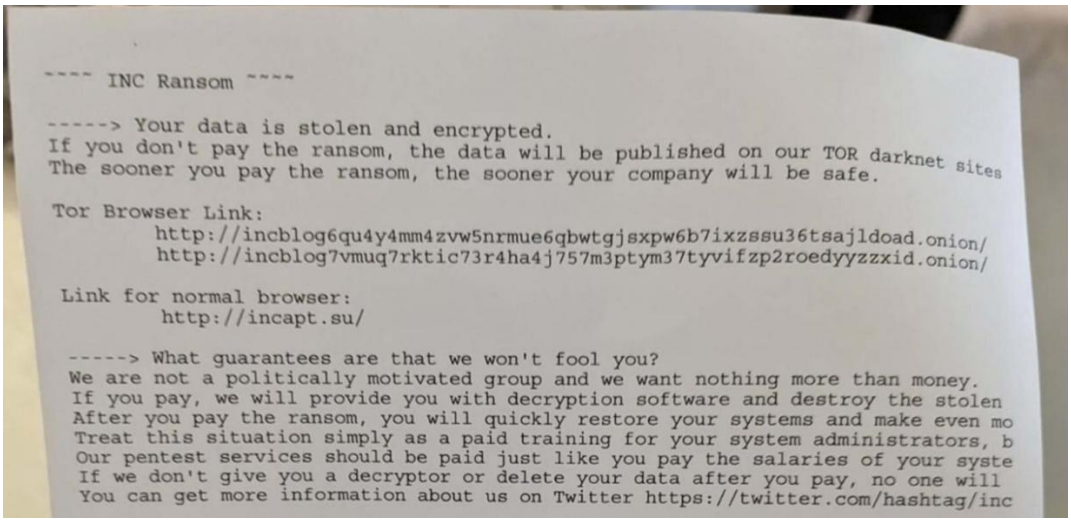
Need for Persistence

In the previous tasks, you have learned how threat actors can remain active on the systems. But why would they need it? Why not just steal the data and exit the system before detection? There can be multiple reasons, but the main ones are:

1. **Add the host to a botnet and use it for further attacks**
    - Like how the Kraken Botnet combines crypto miner, data stealer, and C2 capabilities
2. **Spy on the victim as a part of a state-sponsored campaign**
    - Like how Volt Typhoon stayed undetected in the US electric grid for nearly a year
3. **Use the victim as an entry point to the network, breaching which could take months**
    - Like in the case where threat actors spent 29 days breaching a full network

Active Directory and Ransomware

Let's take a closer look at the third point. In most cases, a Windows network means a large Active Directory that brings its own attacks, detections, and threats - the main one being **ransomware**. Ransomware scares businesses the most. Why? Because it can bring entire companies to a halt, as it did for McLaren hospitals, affecting 743,000 patients. Just imagine seeing your servers encrypted, data stolen, and ransom notes automatically printed on all office printers:


~~~~ INC Ransom ~~~~

-----> Your data is stolen and encrypted.
If you don't pay the ransom, the data will be published on our TOR darknet sites
The sooner you pay the ransom, the sooner your company will be safe.

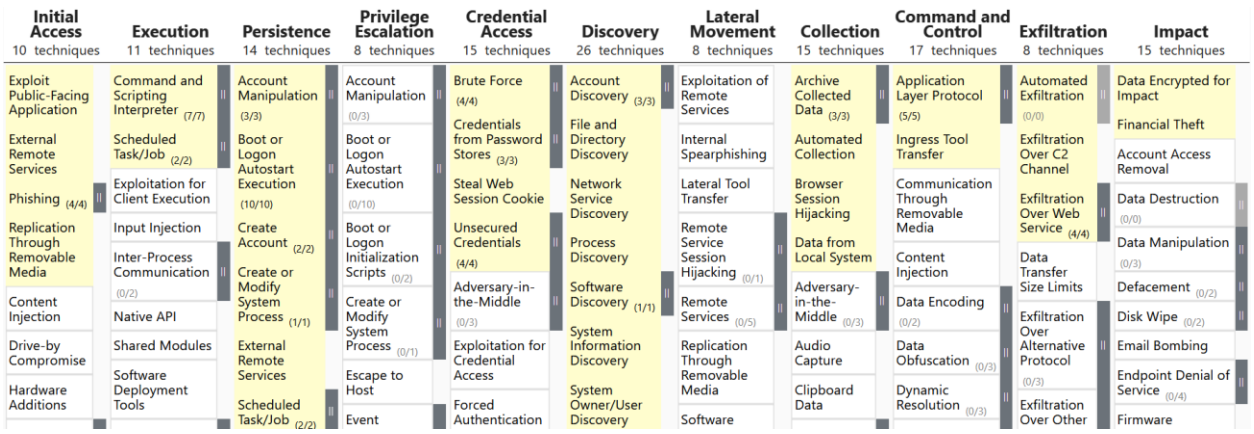
Tor Browser Link:
http://incblog6qu4y4mm4zvw5nrmue6qbwtgjsxpw6b7ixzssu36tsajldoad.onion/
http://incblog7vmuq7rktic73r4ha4j757m3ptym37tyvifzp2roedyyzzxid.onion/

Link for normal browser:
http://incapt.su/

-----> What guarantees are that we won't fool you?
We are not a politically motivated group and we want nothing more than money.
If you pay, we will provide you with decryption software and destroy the stolen
After you pay the ransom, you will quickly restore your systems and make even mo
Treat this situation simply as a paid training for your system administrators, b
Our pentest services should be paid just like you pay the salaries of your syste
If we don't give you a decryptor or delete your data after you pay, no one will
You can get more information about us on Twitter https://twitter.com/hashtag/inc
~~~~

Threat Detection Recap

Active Directory and ransomware are complex topics, but all complex attacks start from a simple single breach. In the Windows Threat Detection rooms, you explored how breaches begin, how the attackers steal data, and how they remain undetected for years. You are now ready to use the acquired knowledge to detect and stop the attacks before ransomware causes a disastrous Impact, preferably right after Initial Access. Here is a quick recap of what you've learned so far (highlighted in yellow):



Answer the questions below

What is the biggest threat to most corporate Windows networks?

Answer: Ransomware

At which stage is it best to detect and stop the attack (e.g. Exfiltration)?

“Right after Initial Access”

Answer: Initial Access